

Cybersecurity Engineering

Introduction to Cybersecurity

uc3m

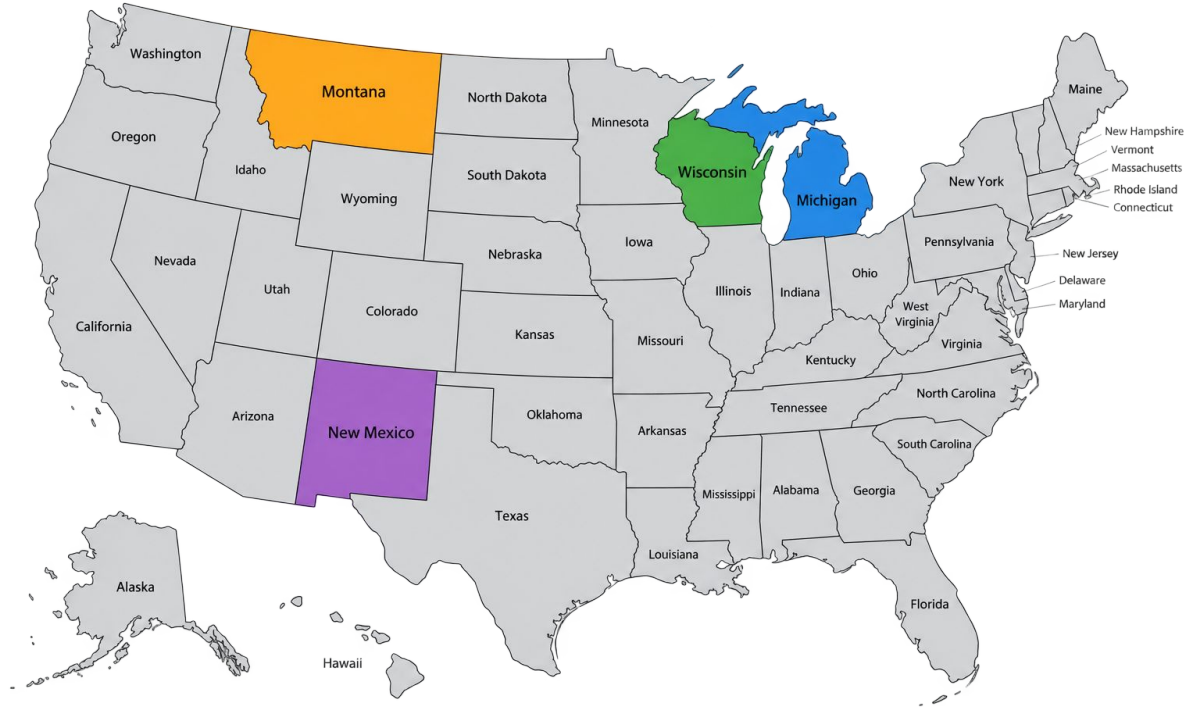
Part I

Computer Security Concepts

Let's start with an anecdote...



February 11,
2013, USA



and an Emergency Action Notification for the following counties:

EMERGENCY ALERT SYSTEM

Civil authorities in your area have reported that the bodies of the dead are rising from their graves and attacking the living. Follow the messages on-screen that will be updated as information becomes available. Do not attempt to approach or apprehend these bodies, as they are considered extremely dangerous. I repeat: civil authorities in your area have reported that the bodies of the dead are rising from their graves and attacking the living. Follow the messages on-screen that will be updated as information becomes available. Do not attempt to approach or apprehend these bodies, as they are considered extremely dangerous. This warning applies to all areas receiving this broadcast. Tune into 920 AM to get updated information in the event that you are separated from your television or if electrical service is interrupted.

LG

100W 400V 100V 100V 100V

What is all this about?

- Almost all of our **modern systems heavily rely on computers** (e.g., water supply, banking services, transportation, health, traffic management, food supply, ...)
- Most of these systems operate as expected, however **occasionally computer-based systems do not work as they should**. This can happen either because of benign failures or malicious attacks.
- The final goal of this course is to **learn about (some) ways computer can fail and how to protect*** against those failures.

*: whenever possible, otherwise at least to *mitigate the effects of* computer failures.

What is computer security?

Computer security is the **protection** of **valuable assets** of a computer or computer system

Assets

Hardware

- Computer
- Devices
- Network gear

Software

- Operating system
- Utilities
- Commercial apps
- Individual apps

Data

- Documents
- Photos
- Music, audio
- Videos
- Email
- Class projects

Value of assets

- Costs
 - Independent monetary cost
 - Replacement cost
 - Personal cost
- Value may be asymmetric for victim and attacker
- Value may result from aggregation, not from individual items

How can things go wrong?

- What bad things can happen to assets?
- Who or what can cause (or allow) those bad things to happen?

Vulnerability-Threat-Control Paradigm

- **Threat:** a set of circumstances that has the potential to cause the loss or harm.
- **Vulnerability:** a weakness in the system that can be exploited to cause loss or harm.
- **Attacker:** someone/something exploiting a vulnerability to perpetrate an attack to the system.
- **Control/countermeasure:** a technique or mechanism that removes or reduces the vulnerability.

Controls prevent threats from exercising vulnerabilities.

CIA: Confidentiality

Only authorized people or systems can access protected data

- Who determines which people or systems are authorized?
- By “accessing” data do we mean reading a file? only part of the file? modifying contents? adding contents? disclosing to other parties?

CIA: Confidentiality

(Access) Policy

Subject + **Access mode** + **Object** = Yes/No

Who

How

What

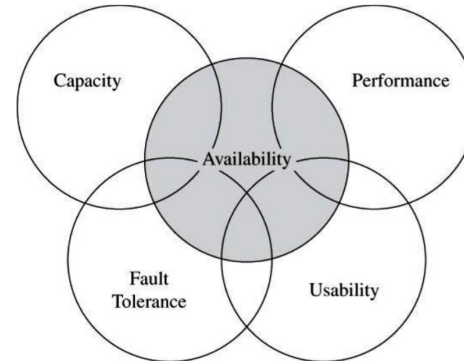
Decision

CIA: Integrity

- *Harder to pin down than confidentiality.*
- Preserving integrity of an item might mean that the item is:
 - Unmodified
 - Modified in authorized ways
 - Modified only by authorized parties
 - Consistent
 - Etc.
- Enforced in the same way that confidentiality is: by **rigorous control of who can access which resources in what ways.**

CIA: Availability

- As integrity, it has different meanings in different contexts.
An object or service is said to be available if:
 - It's present in usable form
 - It has enough capacity to meet the service's needs
 - The service is completed in an acceptable period of time
 - Etc.
- Overlaps with other properties



Access Control

- To implement a policy, computer security controls all accesses by all subjects to all protected objects in all modes of access.
- Small, centralized access control is fundamental to preserving confidentiality and integrity.
- And availability?

Authentication

- The process of discovering (*identification*) or confirming an identity
- Precondition for access control

Vulnerability - Threat - Control

Framework that describes how assets can be harmed and how to counter or mitigate that harm

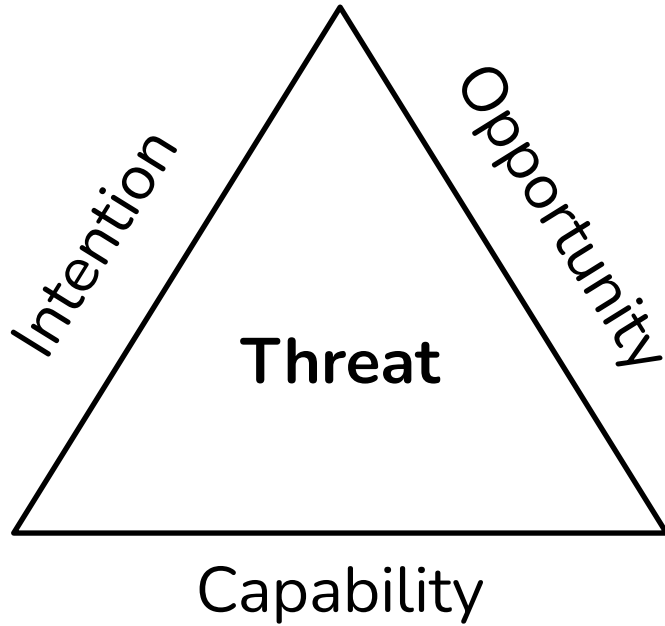
Vulnerabilities

- Weakness in the system (specification, design, implementation, procedures, etc.) that might be exploited to cause loss or harm
- Computer systems have vulnerabilities:
 - Weak authentication
 - Lack of access control
 - Errors in programs
 - Finite or inadequate resources
 - Inadequate physical protection
 - (and more)

Threats

- Set of circumstances that has the potential to cause loss or harm
- An adversary who **exploits** a **vulnerability** perpetrates an **attack** on the system

Threats



Threats

- Basic security properties relate to the **nature of the harm**:

Interception

Interruption

Modification

Fabrication

- Other terms:
 - Disclosure
 - Deception
 - Disruption
 - Usurpation

Types of attackers

Who are they? What motivates them?

- Individuals
 - Fun, challenge, revenge
- Organized, worldwide groups
 - Common financial gains, common political agenda
- Organized crime
 - Fraud, extortion, money laundering, trafficking
- Terrorists
 - Computer as {target, method, enabler, enhancer} of attacks

Controls

Or **countermeasures**: means to counter threats

Action, device, procedure, or technique that removes or reduces a vulnerability

Controls (by goal)

- Prevent** by blocking the attack or closing the vuln
- Deter** by making the attack harder
- Mitigate** by making its impact less severe
- Detect** either as it happens or some time after the fact
- Respond** by managing the incident
- Recover** from its effects

Controls (by type)

Physical Locks, human guards, sprinklers

Procedural Laws, policies, procedures,
(administrative) contracts, copyright, patents

Technical Passwords, encryption, firewalls,
IDS, OS controls

Defense in depth

Overlapping controls—more than one control, more than one class of controls

Part II

Design Principles

Design Principles

- Two rules
- P1 – Least Privilege
- P2 – Fail-Safe Defaults
- P3 – Economy of Mechanism
- P4 – Complete Mediation
- P5 – Open Design
- P6 – Separation of Privilege
- P7 – Least Common Mechanism
- P8 – Acceptability

Two rules

- **Simplicity**
 - Less to go wrong
 - Fewer possible inconsistencies
 - Easier to understand
- **Restriction**
 - Minimize access
 - Inhibit communication

P1 – Least Privilege

- A subject should be given only those privileges necessary to complete its task
 - Function, not identity, controls
 - Rights added as needed, discarded after use
 - Minimal protection

P2 – Fail-safe Defaults

- Default action is to deny access
- If action fails, system as secure as when action began

P3 – Economy of Mechanism

- Keep it as simple as possible
 - KISS principle
- Simple means less can go wrong
 - And when errors occur, they are easier to understand and fix
- Particularly critical for interfaces and interactions

P4 – Complete Mediation

- Check every access
- Usually done once, on first action
 - Some UNIX: access checked on open, not checked thereafter
 - If permissions change after, may get unauthorized access

P5 – Open Design

- Security should not depend on secrecy of design or implementation
 - Popularly misunderstood to mean that source code should be public
 - Secrecy *might* enhance security
 - But if the design becomes exposed, the security of the mechanism cannot be affected
 - “Security through obscurity”

P6 – Separation of Privilege

- With great power comes great ... danger!
- Privilege, or authority, should be split among more than one entity to prevent fraud, sabotage, theft, and other misuses.
 - Classically, the one who signs the checks cannot be the one who prints the checks because then a single person could steal money. (The fraudster has to compromise two persons.)

P7 – Least Common Mechanism

- Mechanism (i.e., resources) should not be shared
 - Information can flow along shared channels
 - Covert channels
- Isolation
 - Virtual machines
 - Sandboxing

P8 – Acceptability

- Security mechanisms should not add to difficulty of accessing a resource
 - Hide complexity introduced by security mechanisms
 - Ease of installation, configuration, use
 - Human factors critical here
 - Psychological factors
 - Personal beliefs

Epilogue

- Key ideas
 - Simplicity – aim at minimum possible complexity
 - Restrictiveness – information wants to be free!
 - Understand
 - the goals of the proposed security, and
 - the environment in which the mechanisms will be developed and deployed